

Security+ 2.4 · Denial of Service

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.4 — Denial of Service (6:07)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: DoS (single source) disrupts a service; DDoS (distributed — botnet of thousands of machines) overwhelms it. Techniques include amplification (large request to an open server that amplifies the response), SYN flood (half-open TCP handshake leaves connections hanging), and ICMP/ping flood. Defenses include CDN (Cloudflare/Akamai in front), rate limiting, scrubbing services, and autoscaling.

High-Yield Core Concepts Tested on Exam

- DoS: single source; DDoS: botnet of thousands — amplifies impact
- Amplification attack: 50-byte request generates 4000-byte response (open DNS/NTP)
- SYN flood: half-open TCP handshake exhausts connection table
- Primary defense: CDN / Cloudflare — absorbs traffic at the edge before it reaches origin

Exam Tips & Classic Scenarios

- 'thousands of machines send traffic simultaneously' = DDoS
- 'uses DNS or NTP servers to amplify traffic' = amplification attack
- 'half-open TCP connections exhaust resources' = SYN flood

Typical Exam Scenario: Scenario: 'An attack takes down the service with traffic from thousands of IPs' = DDoS.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.4 — Denial of Service)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. What type of attack exploits vulnerabilities before a patch is available?

- A)** Zero-day attack
- B)** DDoS attack
- C)** Brute force attack
- D)** Man-in-the-Middle attack

2. The NIST CSF framework organizes security into 5 functions. What are they?

- A)** Install, Update, Test, Audit, Archive
- B)** Identify, Protect, Detect, Respond, Recover
- C)** Plan, Do, Check, Act, Review
- D)** Prevent, Punish, Predict, Prove, Publish

3. Corporate scenario (Denial of Service): During a security review and compliance audit aligned with the CompTIA Security+ (SY0-701, Section 2.4) exam, an analyst evaluates the following technical requirement: 'DoS/DoS: one source; DDoS: botnet of thousands — amplifies'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: DoS/DoS: one source; DDoS: botnet of thousands — amplifies...
- D)** Allow shared access among administrators using generic credentials

4. Corporate scenario (Denial of Service): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Amplification attack: 50-byte request generates 4000-byte response (open DNS/NTP)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Amplification attack: 50-byte request generates 4000-byte response (open DNS/NTP)...
- D)** Allow shared access among administrators with generic credentials

5. Corporate scenario (Denial of Service): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Primary defense: CDN / CloudFlare — absorbs at the edge before it arrives.' What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Primary defense: CDN / CloudFlare — absorbs at the edge before it arrives.
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

6. Corporate scenario (Denial of Service): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'thousands of machines send traffic simultaneously' = DDoS. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'thousands of machines send traffic simultaneously' = DDoS...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (Denial of Service): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'uses DNS or NTP servers to amplify traffic' = amplification attack'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'uses DNS or NTP servers to amplify traffic' = amplification attack...

8. Corporate scenario (Denial of Service): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Scenario: 'an attack takes down the service with traffic from thousands of IPs' = DDoS.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Scenario: 'an attack takes down the service with traffic from thousands of IPs' = DDoS...
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Denial of Service): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'DoS/DDoS: one source; DDoS: botnet of thousands — amplifies'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: DoS/DDoS: one source; DDoS: botnet of thousands — amplifies.

10. Corporate scenario (Denial of Service): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Amplification attack: 50-byte request generates 4000-byte response (open DNS/NTP)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Amplification attack: 50-byte request generates 4000-byte response (open DNS/NTP)...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — Zero-day attack.

✓ **Why it's correct:** The correct answer is 'Zero-day attack'. A zero-day attack exploits a vulnerability that is unknown to the software or hardware vendor, or for which no patch is yet available. The term 'zero-day' refers to the fact that exploitation occurs before the developer has had the opportunity to fix the flaw, or on the same day the vulnerability becomes known. These attacks are particularly dangerous because they cannot be mitigated by antivirus signatures or traditional patches, requiring proactive defenses such as behavioral analysis, sandboxing, and network segmentation. In CompTIA Security+, the zero-day concept is associated with advanced threats and the need for defense-in-depth strategies.

✗ **Why the others are wrong:**

- *DDoS attack:* A DDoS (Distributed Denial of Service) attack aims to overwhelm a service, server, or network with massive traffic from multiple sources, making it unavailable to legitimate users. It does not exploit a specific software vulnerability for which no patch exists; instead, it abuses resource capacity and bandwidth. Although it can be devastating, DDoS does not fit the definition of a zero-day attack, as it does not depend on an unknown and unpatched flaw. Mitigation involves traffic filtering, CDNs, and anti-DDoS services, not patch application.
- *Brute force attack:* A brute force attack attempts to guess credentials (passwords, keys) through exhaustive and repeated attempts, often automated. It exploits weak or predictable passwords, not an unpatched software vulnerability. Although it can be used for initial access, it is not classified as a zero-day attack. Defenses include strong password policies, account lockout, multi-factor authentication, and rate limiting, and do not depend on a specific patch for an unknown flaw.
- *Man-in-the-Middle attack:* A Man-in-the-Middle (MitM) attack occurs when an adversary positions themselves between two communicating parties, intercepting and possibly altering traffic. It exploits authentication flaws, weak encryption, or insecure configurations (e.g., ARP spoofing, DNS spoofing), but is not defined by exploiting an unpatched vulnerability. MitM can be mitigated with strong encryption, digital certificates, and mutual authentication. It is not to be confused with zero-day, which specifically refers to an unknown and unpatched vulnerability.

2) B — Identify, Protect, Detect, Respond, Recover.

✓ **Why it's correct:** The NIST Cybersecurity Framework (CSF) 2.0 organizes cybersecurity activities into five core functions: Identify, Protect, Detect, Respond, and Recover. These functions represent the complete lifecycle of cyber risk management. 'Identify' involves understanding the organizational context, assets, risks, and vulnerabilities. 'Protect' covers implementing safeguards to ensure delivery of critical services. 'Detect' defines activities to identify the occurrence of cybersecurity events. 'Respond' comprises actions taken after an incident is detected. 'Recover' focuses on restoring capabilities or services that were impaired. This framework is widely adopted and required in the Security Architecture and Design domain of the CompTIA Security+ (SY0-701) certification, specifically in objective 2.1, which deals with frameworks and guidelines.

✗ **Why the others are wrong:**

- *Install, Update, Test, Audit, Archive:* These terms describe generic steps of an IT operational process, such as a software lifecycle or patch management, but they do not constitute the NIST CSF functions. 'Install' and 'Update' refer to system deployment and maintenance; 'Test' is a verification activity; 'Audit' is a compliance assessment; and 'Archive' is a data retention practice. None of these actions correspond to the high-level strategic functions defined by the NIST CSF, which are risk-oriented rather than tactical tasks.
- *Plan, Do, Check, Act, Review:* This is a variation of the PDCA cycle (Plan-Do-Check-Act), used in

quality management and continuous improvement systems, such as ISO 9001. Although the NIST CSF can be integrated into continuous improvement processes, its five functions are not 'Plan, Do, Check, Act, Review'. PDCA is a generic management model, while CSF functions are specific to cybersecurity and have their own scope and definitions. The inclusion of 'Review' as a fifth step is a distortion, as the classic PDCA has four steps.

- *Prevent, Punish, Predict, Prove, Publish*: These terms are not part of any recognized cybersecurity framework. 'Prevent' is a goal, but not a CSF function; 'Punish' is a disciplinary or legal action, not a security function; 'Predict' is an aspirational goal, not an operational function; 'Prove' and 'Publish' are audit and communication actions, respectively, but they do not compose the NIST CSF structure. This alternative mixes concepts of justice, prediction, and disclosure, with no relation to the official functions of the framework.

3) C — Implement the corresponding solution: DoS/DoS: one source; DDoS: botnet of thousands — amplifies....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Denial of Service): DoS/DoS: one source; DDoS: botnet of thousands — amplifies. A DoS attack originates from a single source, while a DDoS attack leverages a distributed botnet of thousands of compromised devices to amplify the attack volume and overwhelm the target.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) C — Implement the corresponding solution: Amplification attack: 50-byte request generates 4000-byte response (open DNS/NTP)....

✓ **Why it's correct:** According to the official CompTIA Security+ exam objectives (SY0-701) for lesson 2.4 (Denial of Service): Amplification attack: 50-byte request generates 4000-byte response (open DNS/NTP).

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who made critical changes or malicious commands.

5) A — Implement the corresponding solution: Primary defense: CDN / CloudFlare — absorbs at the edge before it arrives..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Denial of Service): Primary defense: CDN / CloudFlare — absorbs at the edge before it

arrives. A Content Delivery Network (CDN) like CloudFlare distributes traffic across a global network of edge servers, absorbing and mitigating volumetric DDoS attacks before they reach the origin infrastructure. This is a key defense-in-depth strategy for availability.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) B — Implement the corresponding solution: 'thousands of machines send traffic simultaneously' = DDoS....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Denial of Service): 'thousands of machines send traffic simultaneously' = DDoS. A DDoS attack leverages a botnet of thousands of compromised machines to simultaneously flood a target, overwhelming its resources and causing a denial of service. The correct control classification is to recognize this as a DDoS and implement appropriate mitigations such as traffic filtering, rate limiting, and DDoS protection services.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

7) D — Implement the corresponding solution: 'uses DNS or NTP servers to amplify traffic' = amplification attack....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Denial of Service): 'uses DNS or NTP servers to amplify traffic' = amplification attack.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) C — Implement the corresponding solution: Scenario: 'an attack takes down the service with traffic from thousands of IPs' = DDoS....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Denial of Service): Scenario: 'an attack takes down the service with traffic from thousands of IPs' = DDoS. A Distributed Denial of Service (DDoS) attack uses multiple compromised systems (botnet) to flood a target, making it unavailable. Mitigations include rate limiting, traffic filtering, CDNs, and DDoS protection services.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) D — Implement the corresponding solution: DoS/DDoS: one source; DDoS: botnet of thousands — amplifies..

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Denial of Service): DoS/DDoS: one source; DDoS: botnet of thousands — amplifies. A Denial of Service (DoS) attack originates from a single source, while a Distributed Denial of Service (DDoS) attack uses a botnet of thousands of compromised devices to amplify the attack, making it harder to mitigate. Security+ emphasizes the impact of DDoS on availability and the need for mitigation strategies like rate limiting, traffic filtering, and DDoS protection services.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaches compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

10) B — Implement the corresponding solution: Amplification attack: 50-byte request generates 4000-byte response (open DNS/NTP)....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Denial of Service): Amplification attack: 50-byte request generates 4000-byte response (open DNS/NTP). In an amplification attack, the attacker sends a small request to a service that returns a much larger response, using the victim's spoofed IP address. Open DNS resolvers and NTP servers are commonly abused. The correct mitigation is to disable open recursion on DNS servers, restrict NTP monlist, and implement rate limiting and ingress filtering.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks

compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.